

Mapeo de Preguntas de la Encuesta a Requisitos Normativos

Nota: este mapeo es orientativo. Debe adaptarse a la versión y trasposición específica de cada normativa (NIS2, ENS, ISO 27001, NIST, GDPR, DORA, etc.) y a la realidad de cada organización.

Tabla de mapeo

Nº Pregunta (Encuesta)	Tema principal	NIS2 (art./req. gen.)	ENS (categoría/ medida)	ISO 27001 (Anexo A 2022)	NIST CSF 2.0 / SP 800-53	GDPR / DORA / otros
1.1.1	Confianza en inventario de activos	Gestión de activos, requisitos de ciberhigiene	OP.1, OP.2, Inventario de activos	A.5.9, A.5.10, A.8.1	ID.AM-01/02	Aplica indirectamente a resiliencia e integridad de datos
1.1.2	Activos “sorpresa”	Obligación de gestión de riesgos y medidas técnicas	OP.1.1 Inventario y categorización	A.5.9, A.8.1	ID.AM-03, ID.AM-04	–
1.1.3	Existencia de CAASM / capacidades equivalentes	Medidas técnicas adecuadas, supervisión continua	OP, MP (medidas de operación y protección)	A.5.23, A.8.8	ID.AM, PR.IP	–
1.1.4	Fuentes integradas de inventario	Gestión de activos y configuraciones	OP.1, OP.2	A.5.9, A.8.1, A.8.9	ID.AM, PR.IP-01	–
1.2.1	Visibilidad TI tradicional	Gestión de activos, resiliencia operativa	OP.2	A.5.9, A.8.1	ID.AM	DORA: gestión de activos TIC
1.2.2	Visibilidad nube	Seguridad de redes y sistemas, externalización	OP, MP (configuración segura)	A.5.23, A.8.1, A.5.19	ID.AM, PR.AC, PR.IP	GDPR: art. 32 (seguridad del tratamiento)
1.2.3	Visibilidad APIs	Medidas técnicas proporcionadas	OP, MP	A.8.8, A.8.24	PR.AC, PR.DS, PR.PT	–
1.2.4	Visibilidad OT	Sectores esenciales, infraestructuras críticas	OP (entornos industriales)	A.5.9, A.8.1, A.5.15	ID.AM, PR.PT	NIS2: sectores específicos OT
2.1.1	Controles mínimos en activos críticos	Medidas técnicas y organizativas adecuadas	MP (protección)	A.8.8, A.8.9, A.5.11	PR.AC, PR.DS, PR.PT	GDPR art. 32, DORA: controles TIC

2.1.2	Verificación de controles	Supervisión continua, prueba y auditoria	MP, OP	A.5.36, A.5.37	PR.IP, DE (detección)	–
2.1.3	Alineamiento o criticidad- controles	Gestión de riesgos y proporcionalidad	OP.4, MP.1	A.5.4, A.8.1, A.8.28	ID.RA, PR.IP	GDPR art. 32 (riesgo)
2.2.1	Adopción Zero Trust	Medidas de control de acceso, modernización	MP (control de acceso)	A.5.15, A.8.4	PR.AC	–
2.2.2	Visibilidad de identidades privilegiadas	Gestión de cuentas privilegiadas	MP, OP	A.5.15, A.5.18, A.8.2	PR.AC-04/05	GDPR (principio de minimización de acceso)
3.1.1	Visión de servicios expuestos a Internet	Protección de redes y sistemas	MP, medidas de protección perimetral	A.8.20, A.8.24	PR.PT-02/03	–
3.1.2	Exposición OT/IoT	Protección de infraestructuras críticas	OP, MP (segmentación)	A.8.20, A.5.15	PR.PT, PR.AC	–
3.1.3	Gestión de APIs y servicios web	Seguridad de aplicaciones web	MP	A.8.24, A.8.25	PR.PT-03	–
3.2.1	Priorización por probabilidad de explotación	Gestión de riesgos basada en amenaza	OP.4	A.5.4, A.8.8	ID.RA-01/02	–
3.2.2	Uso de inteligencia de amenazas	Monitoreo y respuesta	OP, RE	A.5.7, A.5.36	DE (detección), RS (respuesta)	–
3.2.3	Revisión de modelos de priorización	Mejora continua	OP, MEJORA	A.10.1 (mejora continua)	ID.IM, GV (governance)	–
4.1.1	MTTR exposiciones críticas	Gestión de incidentes	RE (respuesta)	A.5.29, A.5.30	RS.MI-01/02	DORA: tiempos de recuperación

4.1.2	MTTR exposiciones altas	Idem	RE	A.5.29, A.5.30	RS.MI	DORA
4.1.3	Cumplimiento de SLA de remediación	Gestión de servicio y riesgo	OP, RE	A.5.37, A.8.8	PR.IP-11, RS	–
4.2.1	Automatización de remediación	Medidas técnicas de gestión	OP, MP	A.5.23, A.5.36	PR.IP-12, PR.PT	–
4.2.2	Integración con ITSM	Gestión de cambios y configuraciones	OP.2	A.5.33, A.8.9	PR.IP-03/04	–
4.2.3	Revisión de efectividad	Mejora continua de controles	MEJORA	A.10.1	GV, ID.IM	–
5.1.1	Uso de CAASM para cumplimiento	Obligación de demostrar medidas	Informes ENS	A.5.37, A.5.41	GV, ID.GV	GDPR, DORA
5.1.2	Mapeo controles-normas	Gobernanza y cumplimiento	Gobierno ENS	A.5.1, A.5.2	GV (governance)	GDPR, DORA
5.1.3	Reporting ejecutivo	Gobierno corporativo	GOV, OP	A.5.1, A.5.2	GV.OC, GV.RR	–
6.1.1	Estrategia CAASM formalizada	Estrategia de ciberseguridad	Gobierno ENS	A.5.1, A.5.2	GV (estrategia)	NIS2: estrategia de gestión de riesgos
6.1.2	Integración en gestión de riesgos	Gestión de riesgos global	OP.4, Gobierno	A.5.4	ID.RA, GV.RM	GDPR art. 32, DORA
6.2.1	Compartición de información	Cooperación y notificación	NIS2 (cooperación, CSIRT)	COOP	RS.CO, ID.RA-06	GDPR (notificación de brechas), NIS2
6.2.2	Evaluación de terceros	Riesgo de cadena de suministro	OP, MP, proveedores	A.5.19, A.5.20	ID.SC, PR.AT	DORA (terceros TIC)
7.1	Prioridades 12–24 meses	Planes de mejora	MEJORA ENS	A.10.1	GV, ID.IM	–

7.2, 7.3	Autoevaluación abierta	Mejora continua, cultura	Gobierno ENS	A.6.3, A.10.1	GV.CC, ID.IM	—
----------	------------------------	--------------------------	--------------	---------------	--------------	---

Fin del mapeo normativo.